Monitoring, Measurement, Analysis, and Evaluation Procedure

Date	Version	Author	Description	Approved By	Last Updated	Review Frequency	Next Review

Purpose

This procedure defines the approach for monitoring, measuring, analysing, and evaluating the effectiveness of Stark Industries Inc.'s Information Security Management System (ISMS), ensuring continual improvement and compliance with ISO 27001 requirements.

Scope

Applies to all processes, systems, and controls within the ISMS scope, including performance indicators, audit results, incident records, code reviews, vulnerability scans, and penetration testing results.

Objective

- Ensure information security objectives are met (Clause 6.2)
- Identify trends and risks (including technical vulnerabilities)
- Provide inputs for management reviews and continual improvement

Monitoring and Measurement Activities

Metric/Area	Measurement	Frequency	Responsible	Evaluation Criteria
ISMS Objectives	Progress against objectives	Quarterly	IS Manager	At least 80% achieved
Security Incidents	Number, type, response time	Monthly	Security Analyst	Zero critical incidents
Access Control Reviews	Review of access logs and permissions	Quarterly	IT/Infra	No unauthorised access
Training Completion	% of staff completing training	Quarterly	GRC Analyst	100% compliance

Backup Success	Backup completion and restoration tests	Monthly	Infra Engineer	100% success
Patch Management	Timely patching of critical vulnerabilities	Monthly	Infra Engineer	Patches applied within SLA
Secure Code Reviews	Number of issues identified, resolved	For each major release	Developers, GRC Analyst	No critical findings remain unresolved
Vulnerability Scans	Number and severity of vulnerabilities	Quarterly	Security Analyst	High/critical vulnerabilities remediated
Penetration Tests	Number and severity of findings	Annually or major release	External vendor, Security Analyst	High/critical findings remediated
Audit Findings	Number of nonconformities	Annually	Internal Audit	Zero major nonconformities
Log Review and Anomaly Detection	Daily alerts and investigations	Daily	Security Analyst	All anomalies resolved

Methods of Analysis

- Trend analysis (incidents, vulnerabilities, code review issues)
- Root cause analysis for major incidents and pen test findings
- KPI dashboards and management reports
- Comparative performance analysis against objectives and baselines

Evaluation and Reporting

- Results reported in management reviews and shared with relevant teams
- Critical issues (e.g., unpatched vulnerabilities, code review defects) are prioritised for remediation

- Records of reviews, scans, and tests are securely retained and available for audit

Records

- Incident logs and response records
- Secure code review logs and defect tracking
- Vulnerability scan reports and remediation status
- Penetration test reports and remediation status
- Access control and permission reviews
- Training logs and completion records
- Audit reports and findings
- KPI dashboards and reports

Roles and Responsibilities

Role	Responsibilities
Information Security Manager	Oversees monitoring and ensures corrective actions
GRC Analyst	Tracks KPIs, maintains records, prepares reports
Security Analyst	Conducts vulnerability scans, supports pen tests, monitors logs
Developers	Perform secure code reviews and address issues
Infrastructure Engineer	Maintain backups, patching, and access controls
Internal Auditor	Conducts internal audits and reports findings

Review and Updates

This document is reviewed:

- Annually
- Following major role changes or new regulatory requirements
- After significant security incidents or audit findings